Nätverkssäkerhet

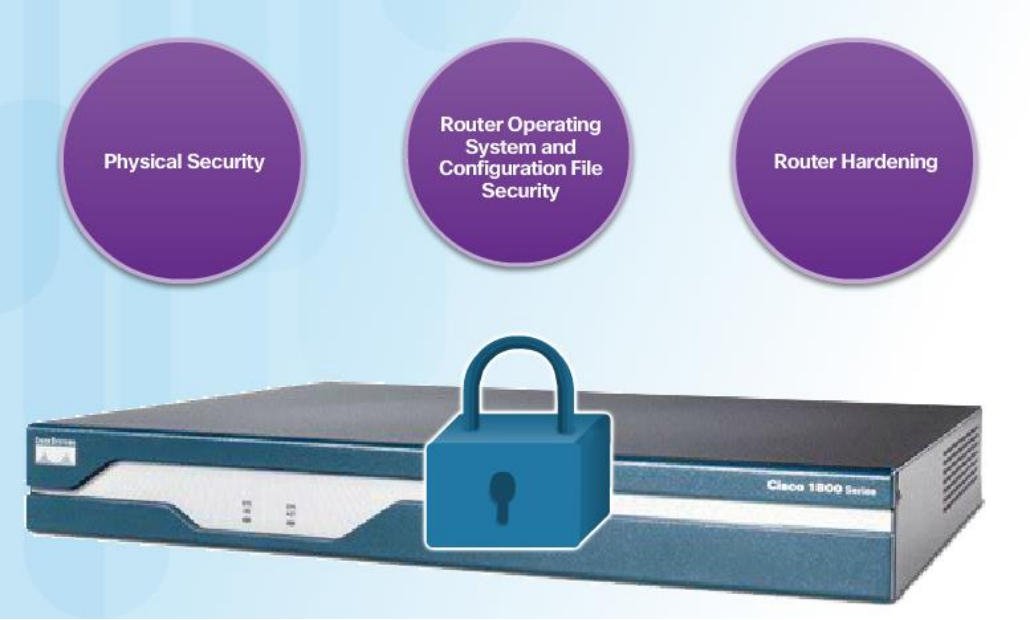
Säkra upp nätverksenheter

Säkra upp nätverksutrustningen

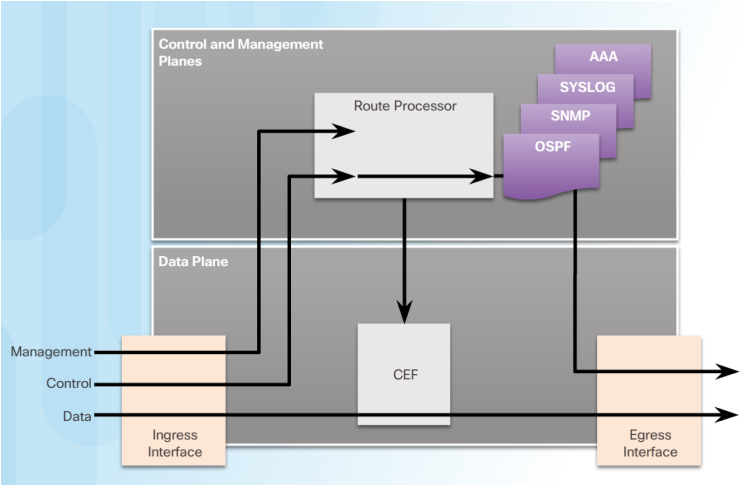
- Första steget är ofta att arbeta utifrån befintlig utrustning
  - Brandväggsregler på routern
  - MAC-filter och DHCP snooping på switchen
  - SNMP, NTP, Syslog, etc. på alla enheter
- Med befintlig utrustning kan man ofta även lägga på autentisering och kryptering, t.ex. på:
  - Lösenord
  - Routinguppdateringar
  - Fjärranslutningar

Tre områden för att säkra upp en enhet

- **Fysisk säkerhet** (Physical security)
  - Placera enheten på ett lämpligt ställe
  - UPS, generator, brandskydd, HVAC
- **Operativsystem och konfigurationsfiler** (OS Security)
  - Ha rejält med RAM
  - Använd alltid senaste stabila OS-versionen
  - Se till att ha en kopia på konfiguration och OS
- **Konfiguration** (Hardening config)
  - Säkra administrativ kontroll
  - Stäng ner oanvända interface
  - Stäng av tjänster som inte används



NFP



- **Control Plane (CoP)**
  - Protokoll och kontrolltrafik från och till andra nätverksenheter, utan direkt interaktion med administratören, t.ex. OSPF, STP, etc.
  - All trafik till själva enheten (router, switch, etc.), vilket också belastar processorn
- **Management Plane (MaP)**
  - Protokoll och trafik för att styra enheten, t.ex. SSH, Telnet
  - Trafiken går via *CoP*, och belastar därmed processorn
- **Data Plane (DaP)**
  - Datatrafiken som skickas genom enheten, t.ex. webbtrafik från användare ut mot Internet
  - Trafik via **DaP** belastar inte processorn

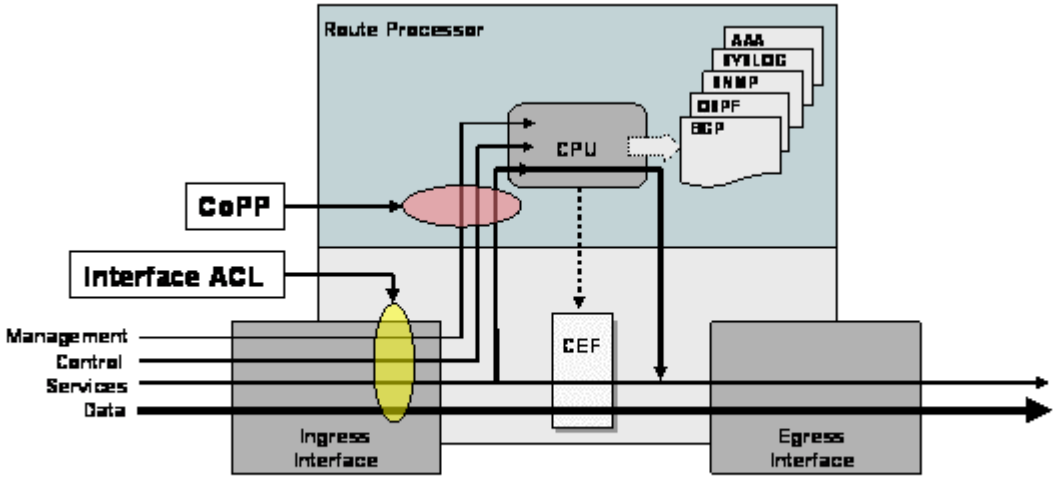
NFP

- Mellan olika plan finns beroenden
  - Om *CoP* inte fungerar, vet inte routern hur den ska vidarebefordra information, d.v.s. DaP fungerar inte
  - Om *MaP* inte fungerar går det inte att göra förändringar, vilket kan påverka både CoP och DaP
  - Svag säkerhet på *MaP* kan även leda till att obehöriga får tillgång till enheten och sänka enheten
  - Om *DaP* inte fungerar, t.ex. till följd av en felaktig ACL, fungerar inte nätverket för vanliga användare, och det går heller inte att komma åt *CoP* och *MaP*

Säkra upp Control Plane

Säkra upp Control Plane

- Efter som trafik till enheten (CoP & MaP) belastar processorn är det en sårbarhet som lätt kan utnyttjas
- För att begränsa trafiken kan man använda sig av **CoPP (Control Plane Policing)**
- Säkra upp routinguppdateringar



CoPP (Control Plane Policing)

- I detta exempel vill vi tillåta ICMP, men med en viss begräsning
- Första steget är att skapa en ACL

```
R1(config)# access-list 101 permit icmp any any echo
```

- Vi vill sedan matcha vår CoPP med access-listan

```
R1(config)# class-map match-all CoPP_ICMP
R1(config-cp)# match access-group 101
```

CoPP (Control Plane Policing)

- Vi vill sedan sätta vår regel

```
R1(config)# policy-map CoPP
R1(config-pmap)# class CoPP_ICMP
R1(config-pmap-c)# police 8000 conform-action transmit exceed-action drop
```

- Sista steget är att aktivera CoPP

```
R1(config)# control-plane
R1(config-cp)# service-policy input CoPP
```

Livelabb – CoPP (Control Plane Policing)

Säkra routing-uppdateringar

- Kommer ni ihåg hur man säkrar routinguppdateringar?

```
R1(config)# interface s0/0/0
R1(config-if)# ip ospf message-digest-key 1 md5 cisco123
R1(config-if)# ip ospf authentication message-digest
```

- MD5 börjar dock bli lite väl svagT

Säkra routing-uppdateringar

- I nya IOS finns det därför funktioner för att istället köra SHA256

```
R1(config)# key chain sonny
R1(config-keychain)# key 1
R1(config-keychain-key)# key-string cisco123
R1(config-keychain-key)# cryptographic-algorithm hmac-sha-256
<…>
R1(config)# interface s0/0/0
R1(config-if)# ip ospf authentication key-chain sonny
```

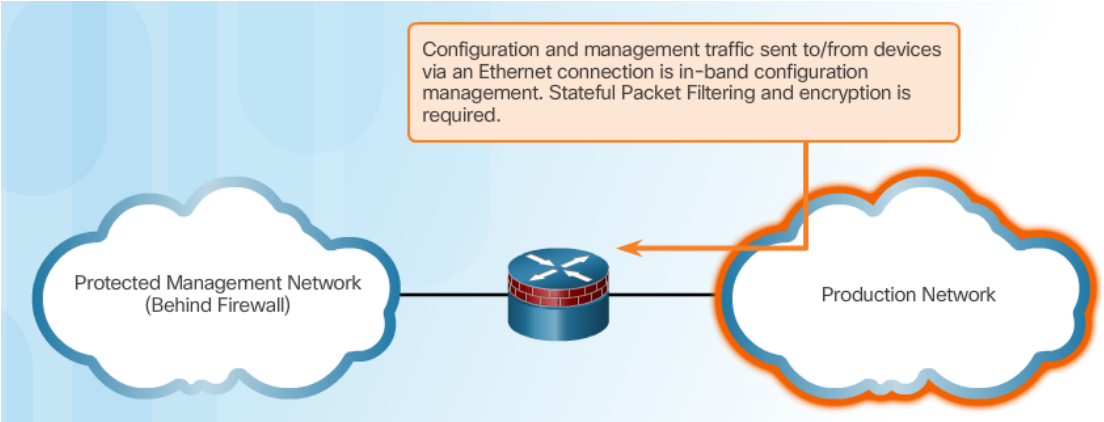
Säkra upp Management Plane

Säkra upp Management Plane

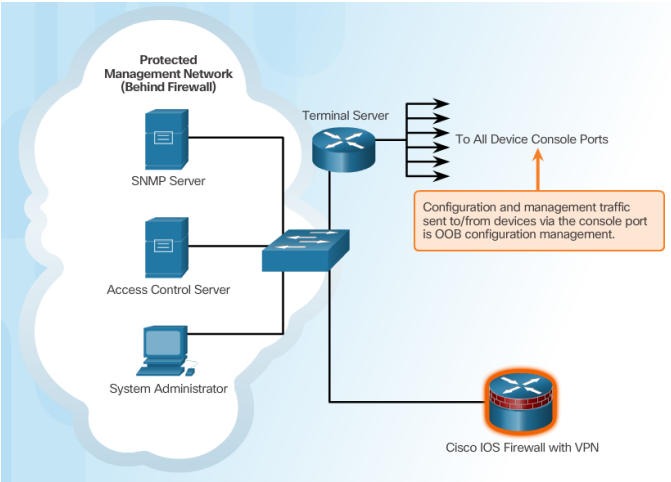
- **AAA (Authentication, Authorization, Accounting)** som vi pratar mer om i nästa föreläsning
- Autentisera **NTP**
- Använd **SSH** istället för Telnet
- Använd någon typ av **RBAC (Role-Based access control)**, t.ex. parser views
- **HTTPS (SSL/TLS)** vid användning av webbgränssnitt (t.ex. ASDM)
- **Skydda okrypterade protokoll** (t.ex. syslog) med en VPN-tunnel, och/eller kör OOB (Out-of-Band Management)

In-Band vs. Out-of-Band MGMT

- **In-Band**
  - Vanliga nätverket för MGMT
  - Använd kryptering (IPsec, SSH)
  - Stäng ner när det inte används



- **Out-of-Band**
  - Separat nätverk för MGMT
  - Ger högsta säkerheten
  - Ingen MGMT-trafik går på produktionsnätverket



Använd säkra lösenord!

- Vad definierar ett säkert lösenord, enligt er?

Ciscos tips för säkra lösenord

- 10 tecken eller mer
- Blanda stora- och små bokstäver, nummer, symboler och mellanrum
- Undvik lösenord med identifierbar information, t.ex. ord, namn
- Felstava gärna ett ord för att komma ihåg det enklare
  - Sonny = Sonneey = s0NnE3y
- Byt lösenord ofta
- Skriv inte ned lösenord (om du inte lagrar dem väldigt säkert…)

Lösenordsregler (enligt forskningen)

- 10 tecken räcker oftast inte
- Att stava ett ord fel är inte så effektivt
- Ett knep för att skapa lösenord är mnemonic-metoden
  - Yan, J., Blackwell, A., Anderson, R., & Grant, A. (2004). **Password memorability and security: Empirical results**. *IEEE Security & Privacy*, 2(5), 25-31.
- Tvinga inte användarna att byta lösenord för ofta
  - Adams, A., & Sasse, M. A. (1999). **Users are not the enemy**. *Communications of the ACM*, 42(12), 40-46
- Många lösenord? Lösenordhanterare kan hjälpa till, men var medveten om riskerna
  - Johansson, S. (2016). **Introducing Password Managers into Multiple-Password Environments**. Luleå Tekniska Universitet, Magisteruppsats

Öka säkerheten på inloggningar

- Minsta teckenlängden i lösenord på en Cisco-router är 6 stycken, detta går att öka med kommandot:

```
R1(config)# security password min-length 15
```

- Ni kommer säkert ihåg kommandot:

```
R1(config)# service password-encryption
```

- En fjärrterminal har som standard timeout på 10 minuter, öka detta:

```
R1(config)# line vty 0 4
R1(config-line)# exec-timeout [minuter] [sekunder]
R1(config-line)# exit
R1(config)# line console 0
R1(config-line)# exec-timeout [minuter] [sekunder]
```

Lagra lösenord säkert

- Lösenord kan lagras med olika typer av algoritmer
  - **0:** Okrypterat
  - **4:** SHA256
  - **5:** MD5
  - **9:** Scrypt (S-Crypt)
- Säkert lösenord för enable:

```
R1(config)# enable algorithm-type md5/scrypt/sha265 secret cisco12345
```

- Säkert lösenord för username:

```
R1(config)# username sonnyfw algorithm-type scrypt secret cisco12345
```

- **OBS: Fungerar endast på våra 2901, samt bara i IOS 15.3(3)M och framåt**

Fler sätt att säkra inloggningen

- Fler metoder för att säkra inloggningen:

```
R1(config)# login block-for [sekunder] attempts [försök] within [sekunder]
R1(config)# login block-for 120 attempts 3 within 30
```

- Undantag går att ställa in enligt:

```
R1(config)# access-list 2 permit 10.0.0.0 0.0.0.255
R1(config)# login quiet-mode access-class 2
```

- Det går även att logga inloggningar

```
R1(config)# login on-success log
R1(config)# login on-failure log
```

SSH (Secure Shell)

- För att SSH ska fungera behövs:

```
R1(config)# ip domain-name dnlab.se
R1(config)# crypto key generate rsa general-keys modulus 1024
<…>
R1(config)# username sonny algorithm-type scrypt secret cisco123
R1(config)# line vty 0 4
R1(config-line)# login local
R1(config-line)# transport input ssh
R1(config-line)# exit
R1(config)# ip ssh version 2
R1(config)# ip ssh authentication-retries 2
R1(config)# ip ssh time-out 60
```

Säkra upp Management Plane

Behörighetsnivåer och views

Behörighetsnivåer (privilege levels)

- Eftersom vi har användare med olika arbetsuppgifter måste vi dela in routern i olika nivåer
- Standard är **privilege level 1** vilket även kallas **User EXEC mode**
  - Känns igen med **Router>** (Här får man utföra vissa show-kommandon)
- **Privilege level 15** är samma sak som administratörsbehörighet. Detta kallas även **Privileged EXEC mode**
  - Känns igen med **Router#** (Här får man utföra alla kommandon)
- Genom att flytta behörighetsnivåer på olika kommandon mellan 1-15 kan vi ge olika behörighetsnivåer till användarna

Ändra behörighetsnivåer

- Görs med kommandot:
  privilege *mode* **level** [level] *command, exempel:*

```
R1(config)# privilege exec level 5 ping
R1(config)# privilege exec level 10 reload
```

- För att använda kommandot *ping* måste vi nu har behörighetsgrad 5 eller högre
- Enable-lösenordet kan skapas med olika behörighetsnivåer

```
R1(config)# enable algorithm-type scrypt secret level 5 cisco123
```

Role-Based Access Control (Parser view)

- Behörighetsnivåer har vissa nackdelar
  - T.ex. kan man på nivå 6 nå alla behörighetsnivåer under
- Istället för nivåer kan man konfigurera man tillgång till ett visst kommando per **Parser view**
  - **Exempelvis:** Helpdesk ska bara ha tillgång till kommandot som börjar på **show**, och vaktmästare ska bara ha tillgång till **show ip interfaces brief**
- En view måste konfigureras av **root view** (priv. 15)
- Flera olika views som bundlas kallas för **superview**, t.ex. om man kombinerar en view för *vaktmästare* och en för *helpdesk*

Konfiguration av views

1. Sätt igång AAA (vad det är tar vi i nästa kapitel)

```
R1(config)# aaa new-model
```

2. Gå in i view-läge

```
R1# enable view
```

(om ingen view specificeras blir det root view)

3. Skapa en view och välj tillåtna kommandon

```
R1(config)# parser view HELPDESK
R1(config-view)# secret cisco
R1(config-view)# commands exec include ping
```

4. Använd parser view HELPDESK

```
R1> enable view HELPDESK
```

Superviews

- En **superview** består av flera andra views. Alla kommandon i respektive view tillåts i en superview
- Det går inte att lägga till egna kommandon i en superview
- Konfiguration av en superview:
  1. Skapa en view
  2. Välj vilka views som ska få vara med i din superview

```
R1(config)# parser view SUPERPOWERS superview
R1(config-view)# secret cisco
R1(config-view)# view HELPDESK
R1(config-view)# view HR
```

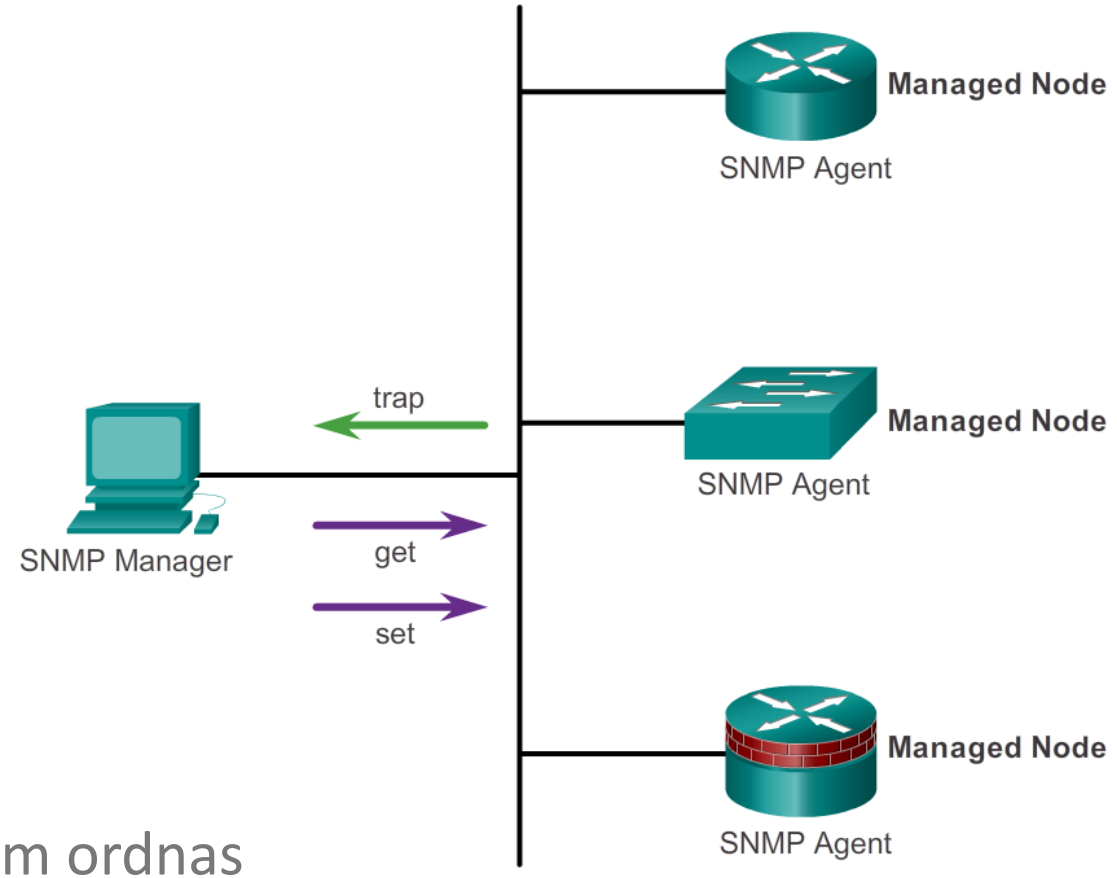
Säkra upp Management Plane

Syslog

- Används för att inhämta loggar från nätverksenheter (klienter)
- I **syslog** specificeras var loggarna ska skickas, t.ex.
  - Logging buffer
  - Console
  - Terminal lines
  - Syslog server
- Filtrering av loggar sker beroende på **severity level** (0-7)
- Har vi pratat om i CCNA 4 (Connecting Networks), känner du dig osäker? Läs på!

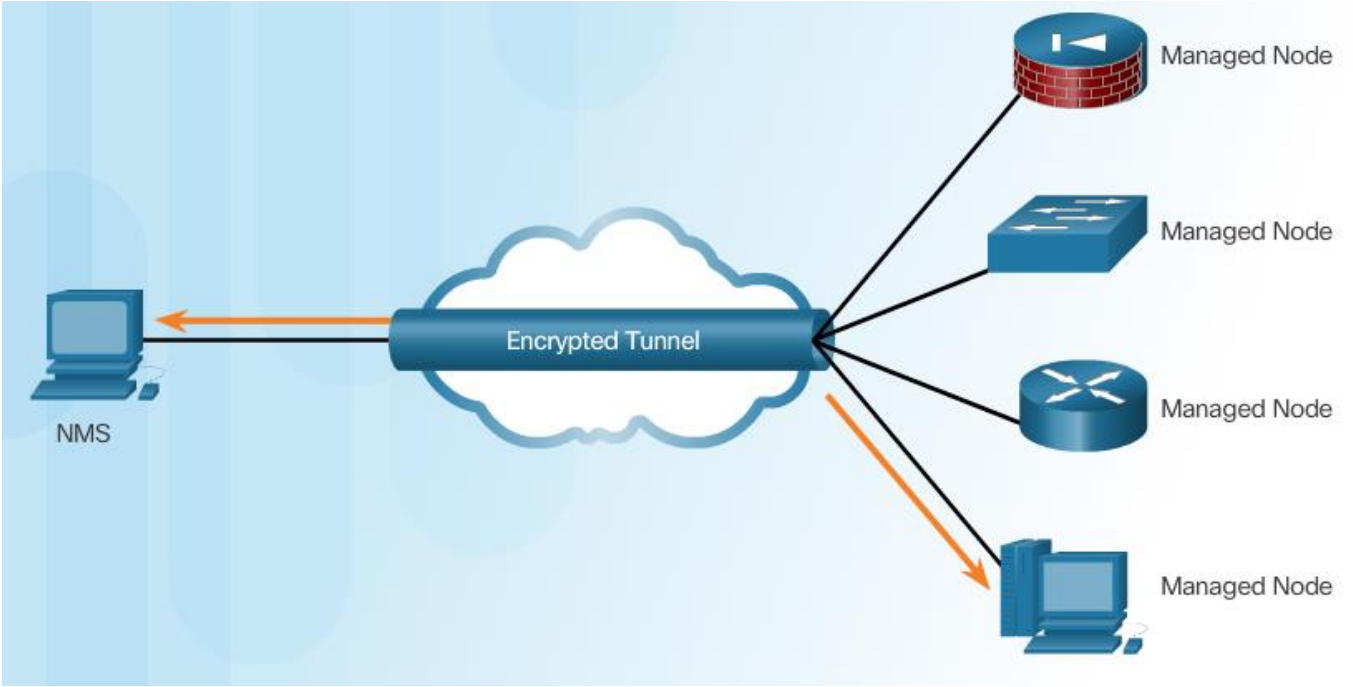
SNMP

- Har vi också pratat om innan!
  - **Roller:** SNMP Manager/Agent
  - **Paket:** SNMP Trap/Get/Set
- SNMP består av en MIB (Management Information Base)
  - MIB:en består av olika OID (object ID) som ordnas hierarkiskt
  - Exempel $\underbrace{1.3.6.1.4.1.9}_{\text{Cisco}}.\underbrace{2.1.56}_{\text{CPU load}}$



SNMP-versioner

- SNMPv2c är det vi har fokuserat mest på tidigare
- Med SNMPv3 får vi:
  - Autentisering och hashsummor
  - Kryptering



Konfigurera SNMPv3

1. Konfigurera en ACL för MGMT-nätet

```
R1(config)# access-list 1 permit 10.0.40.0 0.0.0.255
```

2. Konfigurera en view för SNMP

```
R1(config)# snmp-server view SNMP-VIEW iso included
```

3. Konfigurera en SNMP-grupp

```
R1(config)# snmp-server group HELPDESK v3 priv read SNMP-view access 1
```

4. Konfigurera en SNMP-användare

```
R1(config)# snmp-server user Olle HELPDESK v3 auth sha cisco123 priv
aes 128 cisco12345
```

NTP (Network Time Protocol)

- **Server:**

```
R1# clock set 09:48:00 JAN 18 2017
R1(config)# ntp master 1
R1(config)# ntp authenticate
R1(config)# ntp authentication-key 1 md5 cisco123
R1(config)# ntp trusted-key 1
```

- **Klient:**

```
R1(config)# ntp server 10.0.0.1
R1(config)# ntp authenticate
R1(config)# ntp authentication-key 1 md5 cisco123
R1(config)# ntp trusted-key 1
R1(config)# ntp update-calendar
```

Övriga åtgärder

- **Secure boot-image** – Ett sätt att skydda IOS-filen i flashminnet. Med detta kommando går det ej att se IOS-filen vid fjärrinloggning:
- **Secure boot-config** – Går även att göra med konfigurationen, då skapas en återställningsfil som man endast kommer åt i *rommon*
- **CDP** är som standard igång (stäng av med **no cdp run**)

Säkra upp Data Plane

Säkra upp Data Plane

- Skydd på lager 3 (både IPv4 och IPv6)
  - **Brandväggar**
    - Access-listor (ACL), Zone-Based Policy Firewall (ZPF), ASA (Adaptive Security Appliance)
  - **IDS/IPS** (Intrusion Detection System/Intrusion Prevention System)
- Skydd på lager 2
  - **Private VLANs**
  - **STP-skydd** (root-guard, loop-guard, etc.)
  - **DHCP snooping**
  - **Dynamic ARP Inspection** (DAI)

JÖNKÖPING UNIVERSITY

School of Engineering